

# TriageCounsel — Subprocessor & Data Flow Annex

## (Internal / Customer Diligence)

**Document type:** Internal operational annex — suitable for sharing with enterprise customers, privacy teams, and legal counsel during vendor diligence, DPA negotiation, and security questionnaires.

**Public companion:** [Subprocessors page](#) | [Privacy Policy](#) | [Security page](#)

**Version:** 1.1

**Last updated:** September 2026

**Prepared by:** TriageCounsel (operating entity details per customer agreement; see §2)

### 1. Purpose and scope

This annex provides **detailed, diligence-grade** information about:

- Which third parties process personal data and customer content on behalf of TriageCounsel
- What categories of data each subprocessor receives
- Where data is stored and transferred
- How contract content flows through the platform, including all AI-assisted paths
- Encryption, retention, deletion, and residual-data behavior
- Security and audit controls relevant to subprocessors

This document **supplements** (does not replace) the public Subprocessors page, Privacy Policy, Terms of Service, and any executed **Data Processing Agreement (DPA)** or pilot/evaluation agreement with a specific customer.

**In scope:** Production environment for triagecounsel.com as operated by TriageCounsel.

**Out of scope (not disclosed in this annex):** Internal infrastructure identifiers (hostnames, IP addresses, firewall rules, container orchestration details, credentials, or non-production environments).

### 2. Service provider identity

| Field                                  | Value                                                                                                                                                               |
|----------------------------------------|---------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Trade name                             | TriageCounsel                                                                                                                                                       |
| Service                                | Connected contract review platform — deterministic policy engines, playbook comparison, optional AI-assisted explanations and evidence discovery                    |
| Primary production region              | European Union — Germany (Hetzner Cloud, eu-central)                                                                                                                |
| Legal entity                           | Set via LEGAL_ENTITY_NAME, LEGAL_ENTITY_STATE, LEGAL_ENTITY_ADDRESS environment configuration after LLC formation; displayed on Privacy/Terms pages when configured |
| Contact for privacy/security diligence | <a href="mailto:privacy@triagecounsel.com">privacy@triagecounsel.com</a> (or address specified in customer agreement)                                               |

**Role under GDPR (typical B2B SaaS):**

- TriageCounsel acts as **Processor** for customer-uploaded contract content and associated account data, processing only on documented instructions from the customer (Controller), except where TriageCounsel is Controller for its own account-management, billing, and product-analytics data.
- Exact role allocation should be confirmed in the executed DPA.

---

### 3. Summary subprocessor register

| # | Subprocessor               | Legal entity / HQ   | Processing location(s)                                     | Primary purpose                                                                | Contract content?                                                     |
|---|----------------------------|---------------------|------------------------------------------------------------|--------------------------------------------------------------------------------|-----------------------------------------------------------------------|
| 1 | <b>Hetzner Online GmbH</b> | Germany             | Germany (EU)                                               | Infrastructure hosting — application runtime, PostgreSQL database, Redis cache | <b>Yes</b> — stored encrypted at rest                                 |
| 2 | <b>OpenAI, L.L.C.</b>      | United States       | US and other OpenAI API regions (see OpenAI documentation) | AI-assisted features (see §6)                                                  | <b>Yes</b> — scope varies by feature (excerpts to full document text) |
| 3 | <b>Stripe, Inc.</b>        | United States       | US and other Stripe regions (see Stripe documentation)     | Payment processing, subscription lifecycle                                     | <b>No</b> — billing metadata only                                     |
| 4 | <b>Google LLC</b>          | United States       | US and other Google regions (see Google documentation)     | Optional OAuth sign-in (openid email profile)                                  | <b>No</b>                                                             |
| 5 | <b>SMTP email provider</b> | Per configured host | Per configured SMTP host (production)                      | Transactional email (password reset, notifications)                            | <b>No</b> — recipient address + message body only                     |

**Production email:** Transactional email is delivered via **SMTP** in production (not Resend).

**Not subprocessors (clarification):**

- **PostgreSQL and Redis** run on the same Hetzner-hosted infrastructure — they are not separate third-party SaaS databases.
  - **Original uploaded files (PDF/DOCX bytes)** are not persisted to object storage or any third-party file host.
-

## 4. Personal data and customer content inventory

### 4.1 Account and authentication data

| Data element                     | Stored by TriageCounsel  | Encrypted at rest          | Shared with subprocessors                                               |
|----------------------------------|--------------------------|----------------------------|-------------------------------------------------------------------------|
| Email address                    | Yes                      | No (indexed for login)     | Google (OAuth only, if used); SMTP (delivery); Stripe (billing contact) |
| Name, company                    | Yes                      | No                         | Google (OAuth profile, if used)                                         |
| Password hash                    | Yes (PBKDF2-HMAC-SHA256) | No                         | None                                                                    |
| Google subject ID (google_sub)   | Yes (OAuth accounts)     | No                         | Google (authentication flow)                                            |
| MFA secret (TOTP)                | Yes                      | <b>Yes</b> (EncryptedText) | None                                                                    |
| MFA recovery codes               | Yes                      | No (hashed record)         | None                                                                    |
| Stripe customer/subscription IDs | Yes                      | No                         | Stripe                                                                  |

### 4.2 Contract and playbook content (customer confidential data)

| Data element                                         | Stored by TriageCounsel              | Encrypted at rest          | Shared with subprocessors                                                                 |
|------------------------------------------------------|--------------------------------------|----------------------------|-------------------------------------------------------------------------------------------|
| Original upload bytes (PDF/DOCX)                     | <b>No</b> — processed in memory only | N/A                        | None (not retained)                                                                       |
| Extracted contract text                              | Yes                                  | <b>Yes</b> (EncryptedText) | OpenAI (when AI features run — see §6)                                                    |
| Deterministic findings, policy decisions, deviations | Yes                                  | <b>Yes</b> (EncryptedJSON) | OpenAI (excerpts/context in explanation path; full text in fact-admission/playbook paths) |
| LLM explanation JSON                                 | Yes                                  | <b>Yes</b> (EncryptedJSON) | Generated by OpenAI; stored locally after return                                          |
| Playbook template text                               | Yes                                  | <b>Yes</b> (EncryptedText) | OpenAI (AI-assisted import only, if enabled)                                              |
| Share-link tokens / optional share passwords         | Yes                                  | Password hashed            | None                                                                                      |

4.3 Operational, analytics, and audit data

| Data element                                                    | Stored by TriageCounsel    | Encrypted at rest | Shared with subprocessors |
|-----------------------------------------------------------------|----------------------------|-------------------|---------------------------|
| IP address, user agent                                          | Yes (audit log, analytics) | No                | None                      |
| Signup/acquisition metadata (UTM, referrer, geo)                | Yes                        | No                | None                      |
| Upload metadata (filename, SHA-256, file size, processing time) | Yes                        | No                | None                      |
| Append-only audit events                                        | Yes                        | No                | None                      |

**Important:** Analytics and audit records may **outlive** deleted contracts and deleted user accounts (see §9).

5. End-to-end data flows

5.1 High-level architecture

```
flowchart TB
    subgraph Customer
        U[User browser]
    end

    subgraph EU["Primary hosting – Germany (EU)"]
        APP[TriageCounsel application]
        PG["PostgreSQL – encrypted customer content"]
        RD["Redis – session/cache"]
    end

    subgraph US["United States subprocessors"]
        OAI[OpenAI API]
        STR[Stripe]
        GGL[Google OAuth]
        SMTP[SMTP email]
    end

    U -->|TLS| APP
    APP --> PG
    APP --> RD
    APP -->|TLS – feature-dependent| OAI
    APP -->|TLS – billing only| STR
    APP -->|TLS – optional sign-in| GGL
    APP -->|TLS – transactional| SMTP
```

5.2 Contract upload and analysis flow

- 1. Upload (customer → TriageCounsel, TLS)

- User submits PDF, DOCX, or TXT (max 10 MB).
- File bytes are read into application memory for text extraction (PyPDF2 / python-docx).
- **Original file bytes are not written to disk or object storage.**

## 2. Text extraction and persistence

- Extracted plain text is stored in PostgreSQL as `contract_text` (EncryptedText — AES-256-GCM).
- Filename and upload metadata are stored (filename is not encrypted; content is).

## 3. Deterministic analysis (no third party)

- Rule engine and twelve policy adapters evaluate extracted text on the application server.
- Policy outcomes, findings, scores, and playbook deviations are persisted as EncryptedJSON columns.
- This layer does **not** send data to OpenAI unless a separate AI path is invoked (§6).

## 4. Optional AI explanation (OpenAI)

- If configured, OpenAI receives **deterministic findings** (rule IDs, severities, matched excerpts, rationale) — not necessarily the full contract.
- Output is validated; fabricated issues are dropped.
- See §6.1.

## 5. Optional fact admission / semantic discovery (OpenAI)

- When enabled per policy adapter, OpenAI receives **document text passages** for candidate discovery and adversarial verification.
- See §6.2.

## 6. Results display

- Customer views analysis in authenticated session or via optional password-protected share link.
- Share access attempts are audit-logged.

## 5.3 Authentication flows

| Method               | Data to third party          | Notes                                                  |
|----------------------|------------------------------|--------------------------------------------------------|
| Email + password     | None for auth itself         | Password verified locally; hash never leaves platform  |
| Google OAuth         | openid email profile scopes  | ID token verified via Google JWKS; no contract content |
| Password reset email | Recipient email + reset link | Via SMTP (production)                                  |

**Terms/Privacy acceptance:** New registrations (email and Google OAuth for new users) require acceptance recorded in audit log ( `terms_accepted` event).

## 5.4 Billing flow

- Checkout and subscription management via Stripe Checkout / Customer Portal patterns.
- **Payment card data is collected directly by Stripe** — TriageCounsel stores Stripe customer ID and subscription metadata only.

- Stripe webhooks update subscription status (signature-verified).

## 6. AI processing paths (detailed)

OpenAI is the **only** subprocessor that receives contract content. There are **four distinct code paths**, each with different data scope and authority boundaries.

**Default model:** `gpt-4o-mini` (configurable via `OPENAI_MODEL` ).

**Training:** Per OpenAI API terms, API inputs are not used to train models. TriageCounsel does not use customer data for model training.

### 6.1 Path A — Findings explanation ( `evaluator.py` )

| Attribute           | Detail                                                                                                                                                                              |
|---------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Trigger             | After deterministic analysis produces one or more findings                                                                                                                          |
| Input to OpenAI     | Structured findings only: <code>rule_id</code> , <code>rule_name</code> , <code>severity</code> , <code>matched_excerpt</code> , <code>rationale</code> , <code>overall_risk</code> |
| Full contract text  | <b>Explicitly blocked</b> — passing full text raises a hard error ("LLM LOCKDOWN VIOLATION")                                                                                        |
| Output              | Executive summary bullets, <code>top_issues</code> mapped to findings, suggested missing sections                                                                                   |
| Authority           | LLM <b>cannot</b> change risk scores, severities, or policy decisions                                                                                                               |
| Failure mode        | Falls back to rule-engine-only response; no fabricated findings                                                                                                                     |
| Typical data volume | Short excerpts per finding (operational guard warns if excerpt > 2,000 chars)                                                                                                       |

### 6.2 Path B — Fact admission / semantic verification ( `fact_admission.py` )

| Attribute       | Detail                                                                                                                                                                                                                                                                            |
|-----------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Trigger         | Policy adapters with semantic discovery enabled (per-adapter env flags, e.g. <code>INDEMNIFICATION_SEMANTIC_DISCOVERY_ENABLED</code> )                                                                                                                                            |
| Input to OpenAI | Document text required for evidence verification; depending on configuration, this may include substantial portions or the full contract. Text is wrapped in <code>&lt;document&gt;</code> tags with prompt-injection defenses; candidate propositions are verified adversarially |
| Pipeline        | discover → adversarial verify → mechanical ground (exact substring match in source) → admit/not admit                                                                                                                                                                             |
| Authority       | Module outputs <b>ADMITTED</b> / <b>NOT_ADMITTED</b> only — never ACCEPT/PROHIBITED policy states                                                                                                                                                                                 |
| Failure mode    | Provider errors → <b>NOT_ADMITTED</b> (fail closed)                                                                                                                                                                                                                               |

**Production configuration note:** `POLICY_ENFORCEMENT_MODE=cutover` and `FACT_ADMISSION_MODE=enforced` indicate policy outcomes are authoritative in production; AI assists evidence discovery, not final legal conclusions.

6.3 Path C — AI-assisted playbook import ( `playbook_ai_extraction.py` )

| Attribute       | Detail                                                                                         |
|-----------------|------------------------------------------------------------------------------------------------|
| Trigger         | Customer explicitly uploads prose playbook/guideline for AI-assisted extraction                |
| Opt-in          | Requires <code>AI_ASSISTED_IMPORT_ENABLED=true</code> at operator level <b>and</b> user action |
| Input to OpenAI | Full source document text customer chose to upload                                             |
| Authority       | LLM proposals land as <b>DRAFT</b> fields only; <b>ACTIVE</b> policy requires human approval   |
| Failure mode    | Verification gate; unverified candidates never reach enforcement config                        |

6.4 Path D — Legacy / adapter-specific semantic discovery

Some adapters (e.g. indemnification) may invoke OpenAI via `semantic_discovery_real.py` or adapter-specific discovery before or alongside fact admission. Same principles apply: document text may be sent; outputs are verified and grounded before influencing downstream decisions.

6.5 AI authority summary (customer-facing assurance)

| Capability                                                  | Deterministic engine       | OpenAI                        |
|-------------------------------------------------------------|----------------------------|-------------------------------|
| Risk / policy outcome (ACCEPT, NEGOTIATE, PROHIBITED, etc.) | Authoritative              | Never                         |
| Finding detection (rule engine)                             | Authoritative              | Never                         |
| Plain-language explanation                                  | Fallback if AI unavailable | Generates, validated          |
| Evidence discovery for policies                             | Regex/deterministic first  | Proposes; must pass grounding |
| Playbook rule activation                                    | Human approval required    | Proposes drafts only          |

7. Storage, encryption, and access control

7.1 Encryption at rest

| Mechanism       | Detail                                                                  |
|-----------------|-------------------------------------------------------------------------|
| Algorithm       | AES-256-GCM (authenticated encryption)                                  |
| Envelope format | <code>enc:v1:&lt;key_id&gt;:&lt;nonce&gt;:&lt;ciphertext+tag&gt;</code> |

|                         |                                                                                                                                                                        |
|-------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Key management</b>   | Keys in environment/secrets only (ENCRYPTION_KEYS, ENCRYPTION_KEY_CURRENT); never in database                                                                          |
| <b>Key rotation</b>     | Supported — old rows decrypt under retired key IDs                                                                                                                     |
| <b>Encrypted fields</b> | contract_text, findings_json, llm_result_json, playbook template text, policy/interaction/review JSON blobs, MFA secret, and other EncryptedJSON/EncryptedText columns |

Non-sensitive metadata (filename, timestamps, risk level enum, Stripe IDs) is stored without application-level encryption.

## 7.2 Encryption in transit

All customer and subprocessor communication uses **TLS** (HTTPS).

## 7.3 Tenant isolation

- Every database query for contracts and playbooks is scoped by `user_id` .
- No application code path allows one customer's session to access another customer's documents.
- Administrative access is role-based and audit-logged.

## 7.4 Authentication security

- Passwords: PBKDF2-HMAC-SHA256
- Optional TOTP MFA (encrypted secret at rest)
- Session cookies with CSRF protection on mutating requests
- Rate limiting on sensitive endpoints (login, MFA, password reset)

# 8. International transfers

## 8.1 Primary storage location

**Customer content at rest:** Germany (EU) — Hetzner Online GmbH.

This supports UK GDPR / EU GDPR customers who prefer EU primary hosting.

## 8.2 Transfers outside the UK/EEA

| Subprocessor        | Destination         | Typical transfer mechanism                                                          |
|---------------------|---------------------|-------------------------------------------------------------------------------------|
| OpenAI              | United States       | OpenAI DPA, including SCCs as amended by the UK Addendum for UK Data, as applicable |
| Stripe              | United States       | Stripe DPA / SCCs                                                                   |
| Google              | United States       | Google Cloud/OAuth terms; SCCs where applicable                                     |
| SMTP email provider | Per configured host | Per configured SMTP provider terms / SCCs where applicable                          |

**TriageCounsel position:** Transfers to US-based subprocessors are limited to what is necessary for the feature (OpenAI only for AI features; others for account/billing/email). Primary contract storage remains in Germany.

**Customer action items for UK controllers (e.g. Crescendo):**



1. Execute TriageCounsel DPA with UK GDPR addendum
2. Document OpenAI as sub-subprocessor with transfer impact assessment
3. Confirm OpenAI API data processing terms (zero retention / no training for API)
4. Record EU primary hosting in ROPA

## 9. Retention, deletion, and residual data

### 9.1 Default retention

| Data type                | Default retention                                                                                                 |
|--------------------------|-------------------------------------------------------------------------------------------------------------------|
| Contract text & analysis | While account active, until user deletes contract or account                                                      |
| Playbooks                | While account active, until user deletes or account deleted                                                       |
| Account data             | Until account deletion                                                                                            |
| Optional auto-retention  | Operator may set <code>CONTRACT_RETENTION_DAYS</code> to hard-delete contracts older than N days (off by default) |

### 9.2 User-initiated deletion

| Action                 | Behavior                                                                                                                                                                                                                                  |
|------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Delete single contract | Hard delete of Contract row + cascaded ContractEvent rows; audit event recorded                                                                                                                                                           |
| Delete account         | Hard delete of all Contracts, Playbooks, User row; audit event recorded with email in metadata                                                                                                                                            |
| Cancel subscription    | Via billing settings — sets Stripe <code>cancel_at_period_end</code> ; <b>account deletion does not automatically cancel Stripe subscription</b> (known gap — customers should cancel billing before account deletion or contact support) |

### 9.3 Data that may persist after deletion

| Data type                             | Persists after contract/account delete? | Notes                                                                                                                                                                    |
|---------------------------------------|-----------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Audit log entries                     | <b>Yes</b>                              | Append-only; includes actor, target_id, IP, user agent, event metadata (e.g. deleted user email on account_deleted)                                                      |
| UserAcquisition / UserEvent analytics | <b>Partial</b>                          | Linked via user_id FK with CASCADE on user delete — acquisition row deleted with user; <b>orphaned session/event rows may retain IP/timestamps</b> where not user-linked |
| ContractEvent SHA-256 / filename      | <b>Deleted</b> with contract (CASCADE)  |                                                                                                                                                                          |

|                        |                                        |                                                                                                                                                                                |
|------------------------|----------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Stripe billing records | <b>Yes</b>                             | Retained per Stripe policies and legal obligations                                                                                                                             |
| Database backups       | <b>Yes — up to ~7 days</b>             | Hetzner Cloud automated backups <b>enabled</b> on production; <b>7-slot rotation</b> — when all slots are occupied, the oldest backup is replaced by the next automated backup |
| OpenAI                 | <b>Per OpenAI API retention policy</b> | Typically no training; confirm current OpenAI enterprise/API retention settings                                                                                                |

## 9.4 Data subject requests

Customers should direct erasure/access requests through their Controller (employer) to TriageCounsel as Processor, or directly if TriageCounsel is Controller for account data. Allow time for backup rotation where applicable.

# 10. Subprocessor detail sheets

## 10.1 Hetzner Online GmbH

| Field                 | Detail                                                                                                                                                            |
|-----------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Role</b>           | Infrastructure provider (IaaS) — hosts application, PostgreSQL, Redis                                                                                             |
| <b>Location</b>       | Germany (EU)                                                                                                                                                      |
| <b>Data processed</b> | All persisted customer content (encrypted), account data, audit/analytics                                                                                         |
| <b>Access</b>         | TriageCounsel operator access only; no Hetzner personnel access to application-layer encryption keys                                                              |
| <b>Backups</b>        | Automated server backups <b>enabled</b> ; <b>7-slot rotation</b> on Hetzner Cloud — deleted data may persist in backups for up to approximately <b>seven days</b> |
| <b>Diligence</b>      | Hetzner GDPR documentation, EU data processing terms                                                                                                              |

## 10.2 OpenAI, L.L.C.

| Field                   | Detail                                                                           |
|-------------------------|----------------------------------------------------------------------------------|
| <b>Role</b>             | AI inference API                                                                 |
| <b>Location</b>         | Primarily United States                                                          |
| <b>Data processed</b>   | See §6 — ranges from finding excerpts to full document text depending on feature |
| <b>Sub-subprocessor</b> | Yes — must be listed in customer DPA and transfer assessment                     |
| <b>Diligence</b>        | OpenAI API Data Processing Addendum, security whitepaper, SOC 2 (if applicable)  |

|                          |                                                                                                                                                                                  |
|--------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Customer controls</b> | Disable AI features by not configuring OPENAI_API_KEY (deterministic-only mode); disable AI playbook import via AI_ASSISTED_IMPORT_ENABLED; per-adaptor semantic discovery flags |
|--------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|

### 10.3 Stripe, Inc.

| Field                   | Detail                                                              |
|-------------------------|---------------------------------------------------------------------|
| <b>Role</b>             | Payment processor                                                   |
| <b>Data processed</b>   | Name, email, payment method (direct to Stripe), subscription status |
| <b>Contract content</b> | None                                                                |
| <b>PCI</b>              | Card data never touches TriageCounsel servers                       |
| <b>Diligence</b>        | Stripe DPA, PCI DSS attestation                                     |

### 10.4 Google LLC

| Field                   | Detail                                                       |
|-------------------------|--------------------------------------------------------------|
| <b>Role</b>             | Identity provider (optional)                                 |
| <b>OAuth scopes</b>     | openid email profile                                         |
| <b>Data processed</b>   | Authentication tokens, email, name                           |
| <b>Contract content</b> | None                                                         |
| <b>When active</b>      | Only if GOOGLE_CLIENT_ID and GOOGLE_CLIENT_SECRET configured |

### 10.5 SMTP email provider

| Field                   | Detail                                                                         |
|-------------------------|--------------------------------------------------------------------------------|
| <b>Role</b>             | Transactional email delivery ( <b>production uses SMTP</b> )                   |
| <b>Data processed</b>   | Recipient email, subject, HTML/text body (password reset links, notifications) |
| <b>Contract content</b> | None                                                                           |
| <b>Location</b>         | Per configured SMTP host                                                       |

## 11. Security controls relevant to subprocessors

| Control                   | Implementation                                                                                                                    |
|---------------------------|-----------------------------------------------------------------------------------------------------------------------------------|
| <b>Secrets management</b> | API keys (OpenAI, Stripe, Google, encryption keys) and SMTP credentials in environment variables — not in source code or database |
| <b>Webhook integrity</b>  | Stripe webhook signature verification                                                                                             |
| <b>Upload hardening</b>   | File type and size validation; content extraction in memory                                                                       |

|                                 |                                                                                             |
|---------------------------------|---------------------------------------------------------------------------------------------|
| <b>Audit trail</b>              | Append-only audit_logs — login, upload, delete, export, share, admin, MFA, terms acceptance |
| <b>CSRF</b>                     | Protected POST routes                                                                       |
| <b>Rate limiting</b>            | Login, registration, MFA, password reset                                                    |
| <b>Share links</b>              | Optional password, expiry, max views, revocation; access logged                             |
| <b>Logging discipline</b>       | Contract text not logged; LLM path logs operational metadata only                           |
| <b>Prompt injection defense</b> | Document text treated as untrusted input in AI prompts (<document> wrapping)                |

## 12. Audit event types (representative)

Events recorded in append-only audit log (non-exhaustive):

- login , logout , login\_failed
- register , terms\_accepted
- google\_oauth\_redirect , google\_oauth\_callback
- contract\_uploaded , contract\_deleted , contract\_auto\_deleted
- contract\_exported , batch\_upload\_completed
- share\_link\_created , share\_link\_accessed , share\_link\_revoked
- playbook\_created , playbook\_ai\_import\_completed
- mfa\_enabled , mfa\_disabled
- account\_deleted
- admin\_\* (role-gated actions)

Each entry may include: actor\_user\_id, target\_type, target\_id, IP address, user agent, success flag, detail string, JSON metadata.

## 13. Subprocessor change management

- **Public notice:** Material subprocessor changes will be reflected on <https://triagecounsel.com/security/subprocessors>
- **Customer notice:** Enterprise customers with DPAs should receive advance notice per contract terms (typically 30 days for new subprocessors)
- **Current production list:** Hetzner, OpenAI, Stripe, Google (if OAuth enabled), SMTP email provider (production)

## 14. Diligence checklist for customer privacy teams

Use this checklist when evaluating TriageCounsel for enterprise pilot or production use:

- ☐ Confirm executed DPA and transfer mechanism covering OpenAI as sub-subprocessor (OpenAI DPA, including SCCs as amended by the UK Addendum for UK Data, as applicable)
- ☐ Review which AI paths will be used (explanation only vs. fact admission vs. playbook import)
- ☐ Confirm EU primary hosting meets data residency expectations
- ☐ Document residual audit/analytics data after deletion (§9.3)

- ☐ Confirm Stripe billing data handling if procurement requires separate vendor review
- ☐ Verify OpenAI API terms (no training, retention period) against your policy
- ☐ Note Hetzner backup retention: up to **7 days** (7-slot rotation) for erasure planning
- ☐ Confirm MFA availability for privileged users
- ☐ Review share-link usage policy for your organization
- ☐ Pilot with non-production contracts before full rollout

---

## 15. Known limitations and honest disclosures

These items are disclosed proactively for trust — not as legal admissions:

1. **Not a law firm / not legal advice** — TriageCounsel is software-assisted triage; human legal review remains the customer's responsibility.
2. **AI scope varies** — OpenAI may receive more than short excerpts when fact admission or playbook import is enabled.
3. **Account delete vs. Stripe** — Deleting an account does not automatically cancel an active Stripe subscription; cancel billing separately.
4. **Audit/analytics survival** — Security audit logs and some analytics metadata may persist after content deletion.
5. **Backup window** — Hetzner automated backups use a 7-slot rotation; deleted data may persist in backups for up to approximately **seven days**.
6. **Entity formation** — Legal entity name on public policies updates when LLC formation env vars are configured.

---

## 16. Document history

| Version | Date           | Changes                                                                                                                                           |
|---------|----------------|---------------------------------------------------------------------------------------------------------------------------------------------------|
| 1.1     | September 2026 | SMTP production email; Hetzner 7-day backup retention; OpenAI UK Addendum wording; fact-admission scope clarity                                   |
| 1.0     | September 2026 | Initial internal annex aligned with production architecture (Hetzner EU hosting, EncryptedJSON storage, four AI paths, public subprocessors page) |

---

## 17. Related documents

| Document                    | Location                                                                                                        |
|-----------------------------|-----------------------------------------------------------------------------------------------------------------|
| Public Subprocessors        | <a href="https://triagecounsel.com/security/subprocessors">https://triagecounsel.com/security/subprocessors</a> |
| Privacy Policy              | <a href="https://triagecounsel.com/privacy">https://triagecounsel.com/privacy</a>                               |
| Terms of Service            | <a href="https://triagecounsel.com/terms">https://triagecounsel.com/terms</a>                                   |
| Security overview           | <a href="https://triagecounsel.com/security">https://triagecounsel.com/security</a>                             |
| Data retention (operator)   | docs/security/data_retention_infra.md (internal)                                                                |
| Fact admission architecture | artifacts/fact_admission_architecture/ARCHITECTURE.md (internal)                                                |

---

*This annex is provided for customer diligence purposes. It does not constitute legal advice. Customers should rely on executed agreements and counsel review for compliance decisions.*